4.1 Phishing

Section lead: Henry Peer reviewed by: Brian

4.1.1 Understanding phishing

Phishing remains a primary threat vector within corporate networks, functioning as an entry point for widespread infrastructure compromise. Fundamentally, phishing is a form of social engineering where an adversary masquerades as a trustworthy entity to manipulate targets into surrendering credentials, disclosing confidential information, or initiating unauthorized financial transactions. While traditional phishing campaigns are distributed indiscriminately to broad demographics, attackers increasingly deploy specialized variants designed to exploit specific structural channels.

4.1.2 Defining these variants

from requires precision. Spear phishing replaces mass distribution with targeted reconnaissance, using bespoke details gathered from open-source intelligence to victimise specific individuals. When spear phishing targets corporate executives, it is classified as whaling. Attackers also diversify beyond email protocols. Smishing exploits Short Message Service text channels, relying on the high trust users place in mobile devices. Conversely, vishing utilizes voice over IP telephony or artificial intelligence voice-cloning to simulate urgent verbal commands. The most financially destructive permutation is Business Email Compromise (NCSC, Ncsc Buisness Payment Fraud, 2024). BEC attacks often omit malicious files entirely, relying instead on compromised or spoofed e-mail accounts from those higher in the chain of command to hijack the existing corporate workstations and divert corporate funds wherever the attacker wants.

4.2 The way phishing works

The operational efficiency of these attacks relies heavily on exploiting established human phycological biases. Some social engineering literature indicates that security measures are frequently bypassed by manipulating a target's psychological state. Attackers heavily exploit urgency by enforcing artificial, condensed deadlines. This structural constraint forces individuals into rapid, heuristic decision-making, which severely degrades their analytical faculties (S. Grazioli, 2000).

This state is routinely amplified by projecting an aura of authority. As demonstrated in foundational psychological paradigms, individuals are socially conditioned to comply with instructions issued by perceived superiors, this is notable demonstrated in the famous Milgram experiment (Milgram, 1963). In a corporate setting, a message mimicking an executive or some form of legal entity instinctively dampens a subject’s inclination to verify the request. Furthermore, attackers exploit fear and loss aversion by

threatening professional reprisal or system suspension. Alternatively, they may exploit helpfulness or curiosity. These intense emotional triggers effectively blind targets to contextual anomalies.

4.3.1 Identifying phishing

To identify these fraudulent communications, international bodies like the UK National Cyber Security Centre (NCSC, Annual Review 2025, 2025) and the US Cybersecurity and Infrastructure Security Agency (CISA, SECURING HIGH VALUE ASSETS, 2018) provide formal guidance detailing core indicators of deception. A primary indicator is a discrepancy within sender identities. Attackers routinely employ 'typo squatting' to mimic corporate domains or forge display names to mask external email addresses. Examining the absolute header data rather than the friendly display name reveals these variances.

Furthermore, the nature of the request itself serves as an indicator. Phishing attempts often look for immediate credential validation e.g.: changes to banking details, or the execution of unusual internal processes usually bypassing security methods. While early guidance focused on poor spelling or grammatical errors, modern adversaries utilize generative artificial intelligence to produce linguistically polished messages that mimic the usual formal emails sent. Consequently, contemporary guidance highlights structural anomalies. These include generic greetings in place of personalized communication, mismatched destinations when hovering over hyperlink text, and requests that actively circumvent standard internal approval pathways. This can often times be the phishing messages greatest weakness as anyone with the know-how to check for such details or any company with a security setup telling the user if the message originated from inside or outside the company can show the phishing messages true intent.

4.3.2 Preventing phishing

When a phishing interaction is suspected it's important that the organisation or individual does not click on any link and instead report it to the NCSC by emailing report@phishing.gov.uk and let their takedown service investigate, hunt down and ultimately blacklist the suspicious email address if its found to be a phishing scam.

It's also important to block the email address so it doesn't pose any further security risk (e.g. if one department is sent an email then doesn't block it, then another department that is unaware of the risk falls for the scam it could pose a continuous security risk.

4.4 Recommended Response

When a phishing incident occurs within an organization, they must trigger an immediate incident response framework spanning individual and organizational dimensions.

An individual who identifies a suspected message before interacting with it must completely isolate the message. This means they must not reply to the sender open any links, download attachments. If an individual has already clicked a link or submitted data, they must immediately disconnect their endpoint from local wireless or wired networks to stop any potential malware from spreading laterally. The incident must then be reported through designated internal channels, such as a secure IT service desk telephone or a dedicated reporting button.

Organizationally, the security operations team must isolate the affected device from the broader network infrastructure. They must perform a comprehensive mail system sweep to purge identical messages from all corporate inboxes. If credentials were stolen, administrators must terminate active user sessions and enforce an enterprise-wide password reset, it's also a good idea to temporarily remove user group access to any sensitive data or systems from anyone but important IT responding staff. If a BEC attack has initiated a fraudulent wire transfer, the organization must instantly notify internal legal counsel and contact the banking institution to initiate a transaction freeze. Finally, a post-incident review must be completed to update email filtering rules and improve security awareness training modules based on the attack methodology.